Access Control

Definition

ACCESS CONTROL : Security mechanism that ensures that "all accesses and actions on objects by principals are WITHIN the security policy"

DISCRETIONARY ACCESS CONTROL (DAC)

- Object owners assign permissions
- Ownership of resources
- Windows, Linux, macOS
- Social Networks

MANDATORY ACCESS CONTROL (MAC)

Central security policy assigns permissions

- Organizations with need for central controls
- Military – focus on confidentiality
- Hospital environment – focus on confidentiality and integrity
- Banking – focus on integrity

DAC

Definition

ACCESS CONTROL MATRIX : an abstract representation of all permitted triplets of (subject, object, access right) within a system

- **Subjects (principals) :** entity within an IT system
  a user, a process, a service
- **Objects (assets) :** resources that (some) subject may access or use
  a file, a folder, a row in a database, the system's memory, a machine in the network, a printer, a page in a website
- **Operations :** in abstract, subjects can observe and/or alter objects
  read, write, append, execute

Role Based Access Control (RBAC)

Key idea

Subjects are similar to each other : assign same rights

Example

e.g., a doctor has the same privileges as another doctor

1. assign permissions to roles
2. assign roles to subjects
3. subjects select an active role – they have the permissions of the active role

Warning

RBAC Problems

Problem 1 : Role Explosion

- Temptation to create fine grained roles, denying benefits of RBAC

Problem 2 : Simple RBAC has limited expressiveness

- Problems with implementing least privilege
- Some roles are relative : "Alice's Doctor" vs. "Any Doctor"

Problem 3 : Difficult to implement separation of duty

- "Two doctors are needed to authorize a procedure"
- RBAC Mechanism needs to ensure they are distinct!

Group Based Access Control

Key idea

Observation : Some permissions are always needed together

Example

e.g., access to sockets and network interface always go hand in hand

1. assign permissions to access objects to groups
2. assign subjects to groups
3. subjects have the permissions of all their groups

Ambient Authority

Definition

AMBIENT AUTHORITY is used by a subject if for an action to succeed it only needs to specify the operation and the names of the involved object(s)

- no need to repeat the subject all the time (usability)
- least privilege becomes harder to enforce

Warning

confused deputy problem! PK????

The confused deputy problem

Problem with ambient authority :

Key idea

A privileged program can be tricked to misuse its authority
(Confused deputy problem)

Solutions :

1. Re-implement access control in the privileged process
2. Let privileged process check authorization for Alice.
3. Capabilities can help!

Files have ACLs attached to them

- Each file is assigned an owner UID and GID → GID???
- Each file has 9 permission bits